

2. **SIMPLIFIED CHECKLISTS**

A set of simplified checklists to
comply with each of the 12
Requirements.



IMPLEMENTATION

IMPLEMENTATION SIMPLIFIED CHECKLISTS

Let's cover some simplified compliance checklists.

(Disclaimer: These don't include all sub-requirements! Use as a complement!). Starting with Requirement 1:

- Document + enforce policies and procedures
- Document + enforce roles and responsibilities
- Define and implement NSC configuration standards
- Have a change management process for NSC configs.
- Have an accurate network diagram
- Have an accurate data flow diagram
- Identify and justify allowed services/protocols/ports
- Implement security for insecure network devices
- Periodically review NSC configurations
- Restrict inbound + outbound network traffic

IMPLEMENTATION

SIMPLIFIED CHECKLISTS

For Requirement 2:

- Document + enforce policies and procedures
- Document + enforce roles and responsibilities
- Develop configuration standards for all systems
- Manage vendor default accounts
- Isolate system functions by security level
- Remove unnecessary services and protocols
- Secure insecure services and protocols
- Configure system security parameters
- Encrypt non-console admin access
- Manage wireless vendor defaults





IMPLEMENTATION

IMPLEMENTATION SIMPLIFIED CHECKLISTS

For Requirement 3:

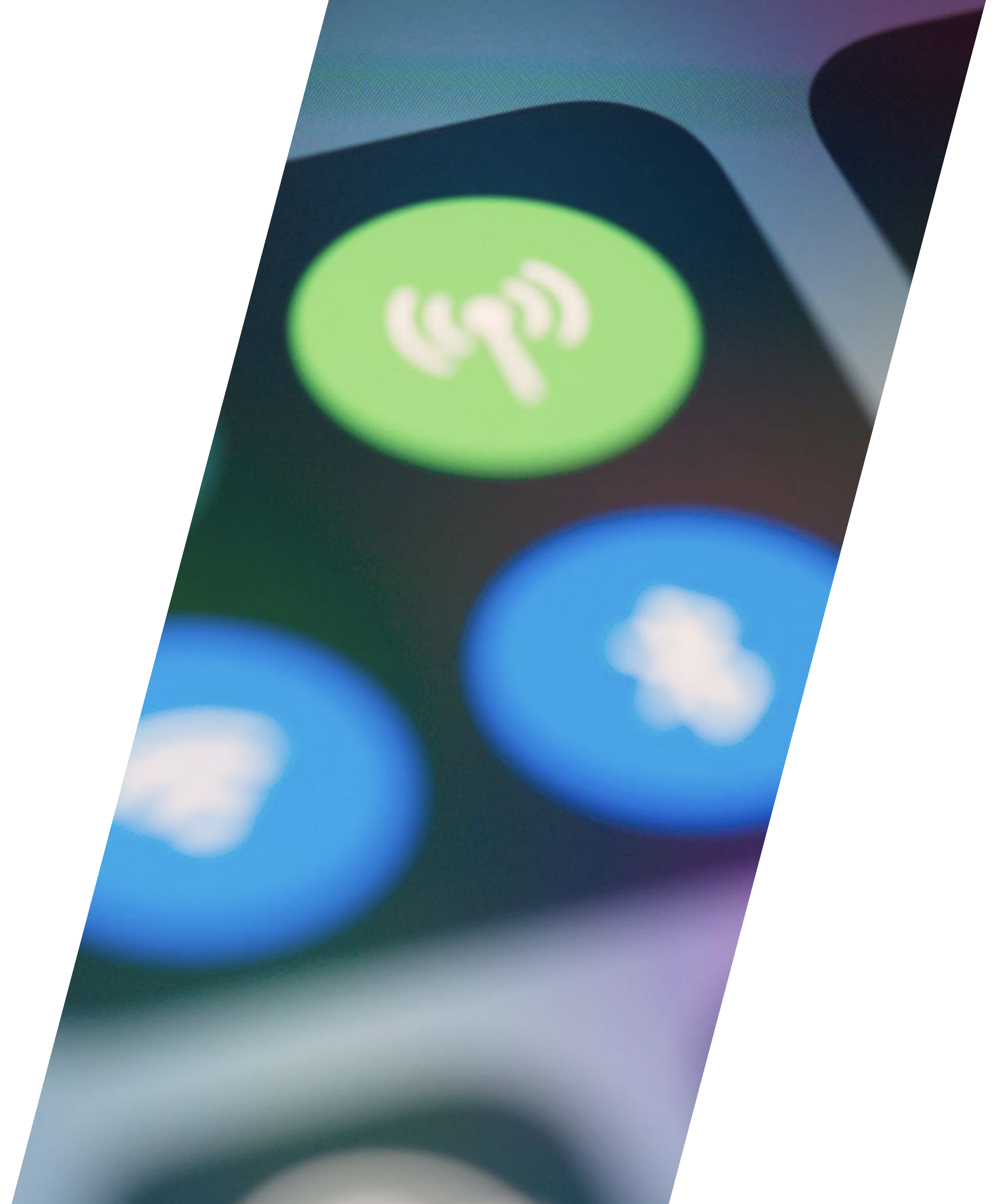
- Document + enforce policies and procedures
- Document + enforce roles and responsibilities
- Minimize storage of account data
- Do not store SAD of any type
- Encrypt/render unreadable all cardholder data (e.g. PANs)
- Mask PANs when displayed (BIN + 4 last four max)
- Restrict access to full PANs
- Implement processes for secure deletion
- Have strong key management processes
- Regularly verify encryption keys and data controls

IMPLEMENTATION

SIMPLIFIED CHECKLISTS

For Requirement 4:

- Document + enforce policies and procedures
- Document + enforce roles and responsibilities
- Encrypt PANs in public, open networks
- Use only trusted keys and certificates
- Have an updated inventory of trusted keys/certificates
- Ensure strong encryption on CDE-connected wireless networks
- Disable fallbacks to insecure versions or configurations
- Secure PANs in user-messaging applications
- Regularly monitor and verify cryptographic protocols
- Have controls to reject untrusted keys or certificates





IMPLEMENTATION

IMPLEMENTATION SIMPLIFIED CHECKLISTS

For Requirement 5:

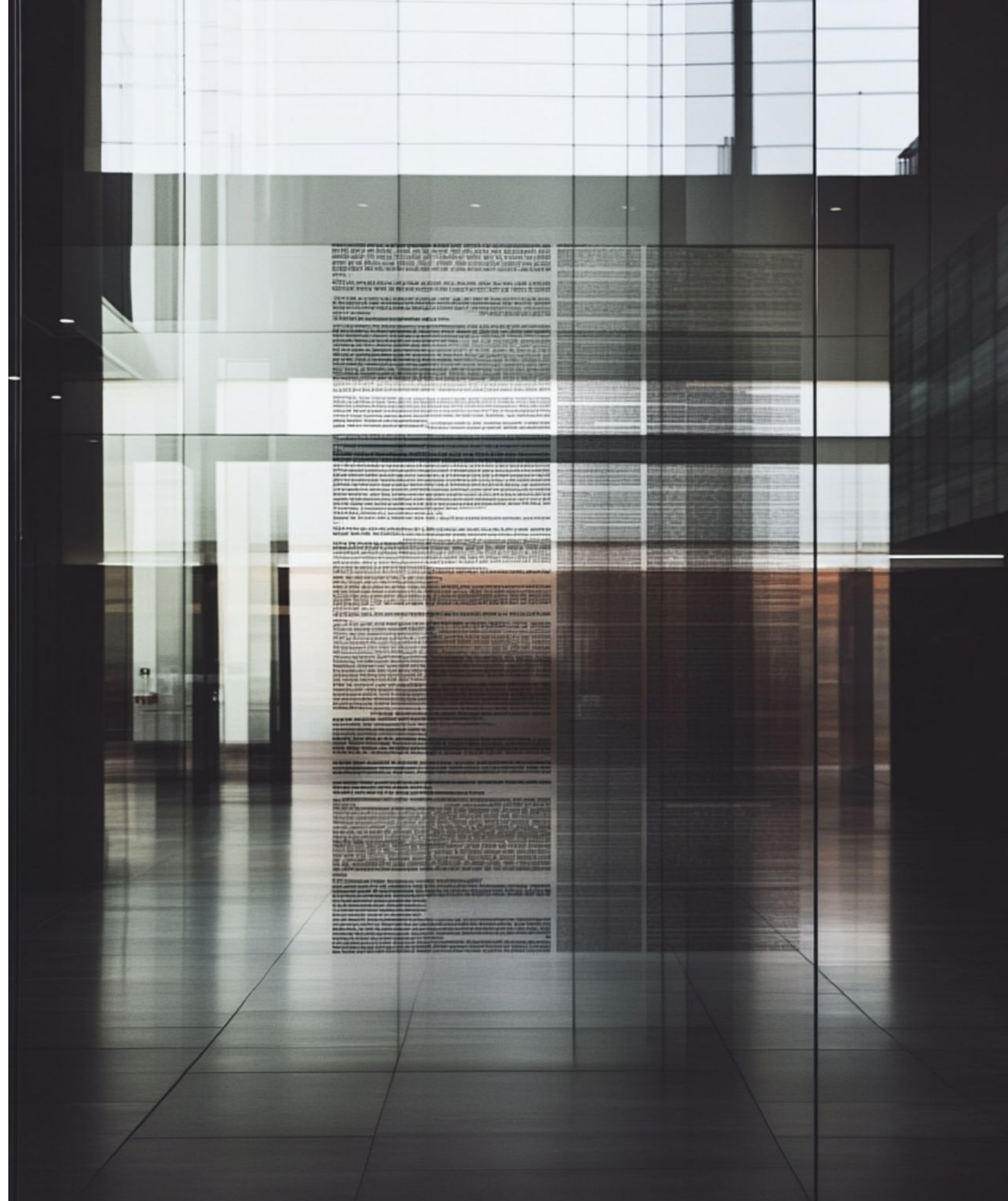
- Document + enforce policies and procedures
- Document + enforce roles and responsibilities
- Deploy anti-malware solutions
- Ensure anti-malware detects/blocks/removes all malware types
- Periodically review exempted system components
- Configure anti-malware automatic updates
- Perform regular and real-time malware scans
- Ensure removable media are scanned for malware
- Retain audit logs of anti-malware for at least 12 months
- Prevent disabling or altering anti-malware solutions

IMPLEMENTATION SIMPLIFIED CHECKLISTS

For Requirement 6:

- Document + enforce policies and procedures
- Document + enforce roles and responsibilities
- Develop software with security best practices in the SDLC
- Train software developers on security annually
- Conduct code reviews prior to production release
- Use secure coding techniques for common vulnerabilities
- Identify and address security vulnerabilities with patching
- Maintain an inventory of bespoke and 3rd-party software
- Protect public-facing web applications
- Have a change management process for software changes





IMPLEMENTATION

IMPLEMENTATION SIMPLIFIED CHECKLISTS

For Requirement 7:

- Document + enforce policies and procedures
- Document + enforce roles and responsibilities
- Define an access control model based on PoLP and NtN
- Assign access to users based on role and functions
- Ensure access privileges are authorized and documented
- Review user access privileges (including 3rd parties) every 6 months
- Limit access to system and application accounts
- Review application and system account privileges
- Restrict direct access to CHD data repositories
- Enforce privileges with an AC system that "denies all" by default

IMPLEMENTATION **SIMPLIFIED CHECKLISTS**

For Requirement 8:

- Document + enforce policies and procedures
- Document + enforce roles and responsibilities
- Ensure all users have a unique ID
- Restrict shared or generic accounts
- Properly manage account lifecycle
- Revoke access for terminated users immediately
- Disable inactive accounts within 90 days
- Limit third-party access through limited time and monitoring
- Implement MFA for access to critical components
- Enforce session timeouts after 15 minutes





IMPLEMENTATION

IMPLEMENTATION **SIMPLIFIED CHECKLISTS**

For Requirement 9:

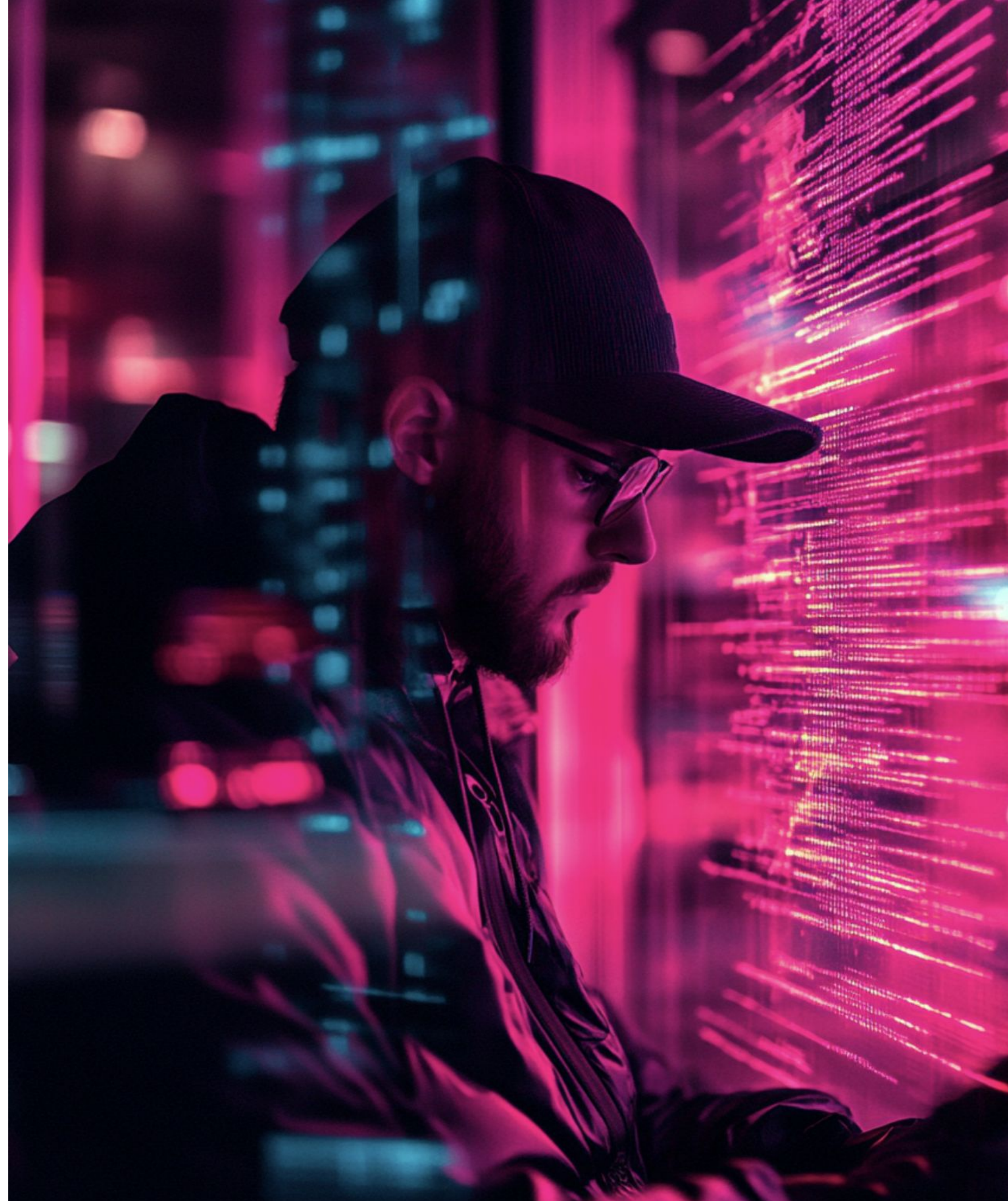
- Document + enforce policies and procedures
- Document + enforce roles and responsibilities
- Implement facility entry controls
- Monitor access to sensitive areas
- Restrict access to publicly accessible network jacks
- Restrict physical access to networking/comms hardware
- Control access to physical consoles in sensitive areas
- Manage personnel and visitor access
- Enforce visitor management procedures
- Properly manage secure media with CHD data

IMPLEMENTATION **SIMPLIFIED CHECKLISTS**

For Requirement 10:

- Document + enforce policies and procedures
- Document + enforce roles and responsibilities
- Enable and activate audit logs
- Capture all access and actions of users and admins
- Record specific audit log details
- Ensure audit logs are protected from access/modification
- Back up audit logs
- Monitor audit logs using FIM or change detection
- Review audit logs of certain categories daily
- Retain audit log history for 12 months (3 months immediate)





IMPLEMENTATION

IMPLEMENTATION SIMPLIFIED CHECKLISTS

For Requirement 11:

- Document + enforce policies and procedures
- Document + enforce roles and responsibilities
- Detect and monitor wireless APs every 3 months
- Maintain an inventory of authorized wireless APs
- Conduct internal vulnerability scans every 3 months
- Conduct external vulnerability scans (ASV) every 3 months
- Perform internal + external penetration tests every 12 months
- Correct vulnerabilities and security weaknesses found
- Validate segmentation controls with pentesting if using it
- Use IDS and IPS techniques at CDE perimeter + critical junctures

IMPLEMENTATION

SIMPLIFIED CHECKLISTS

For Requirement 12:

- Establish and maintain an overall InfoSec policy
- Define and assign InfoSec roles and responsibilities for all personnel
- Develop and enforce acceptable use policies
- Perform targeted risk analyses for every requirement with flexible frequency
- Maintain an inventory of all systems and components in scope every 12 months
- Engage and monitor third-party service providers (TPSPs)
- Implement a security awareness + training program
- Screen personnel before hiring
- Develop, test and maintain an IR (Incident Response) plan, with 24/7 people



IMPLEMENTATION

SIMPLIFIED CHECKLISTS

EXAMPLES

/01 COMMON SENSE

The targeted risk analyses in Requirement 12 are just a formal way of saying “Choose the frequency that makes sense for each control... but do justify it”.

/02 SAME OUTCOMES

A lot of security controls have a customized approach that allows a different control or technique to be used, as long as the result is exactly the same.

/03 SMALL, WEIRD ISSUES

Remember we also have to protect against issues that may be small (even random), but that can affect us (e.g., a logger running out of disk space and stopping).

IMPLEMENTATION

IMPLEMENTATION

SIMPLIFIED CHECKLISTS

KEY TAKEAWAYS

/01 A
A

/02 A
A

/03 A
A

/04 A
A

/05 A
A

/06 A
A